



សាកលវិទ្យាល័យភូមិន្ទភ្នំពេញ
ROYAL UNIVERSITY OF PHNOM PENH

**មូលដ្ឋានសុវត្ថិភាពសម្រាប់ហេដ្ឋារចនាសម្ព័ន្ធព័ត៌មានវិទ្យារបស់
ស្ថាប័ន**

Security Based Practices for an Organization IT infrastructure

A Research Report
In Partial Fulfilment of the Requirement for the Degree of
Master of Science in Information Technology Engineering

CHAN OEURN

December 2019

សាកលវិទ្យាល័យភូមិន្ទភ្នំពេញ
ROYAL UNIVERSITY OF PHNOM PENH

**មូលដ្ឋានសុវត្ថិភាពសម្រាប់ហេដ្ឋារចនាសម្ព័ន្ធព័ត៌មានវិទ្យារបស់
ស្ថាប័ន**

Security Based Practices for an Organization IT infrastructure

A Research Report
In Partial Fulfilment of the Requirement for the Degree of
Master of Science in Information Technology Engineering

CHAN OEURN

Examination committee: Mr. Kor Sokchea
Mr. Heng Sokha
Ms. Seng Monika

December 2019

មូលដ្ឋានសង្ខេប

អ៊ុនធឺណិតមានការរីកចម្រើនយ៉ាងខ្លាំងក្នុងរយៈពេលមួយទសវត្សរ៍ចុងក្រោយនេះ និងមានតម្រូវការគ្រប់ទីកន្លែង ហើយអ៊ុនធឺណិត គឺជាតម្រូវការសំខាន់នៅក្នុងការប្រើប្រាស់ប្រចាំថ្ងៃរបស់យើងគ្រប់គ្នា។ វាជាធនធានដ៏ល្អសម្រាប់ធ្វើការតភ្ជាប់ និងចែករំលែកព័ត៌មាន តែបើការប្រើប្រាស់មិនបានត្រឹមត្រូវក្នុងពេលជាមួយគ្នានោះ វាក៏មានការគំរាមកំហែងពីសំណាក់ក្រុម (Hacker)។ ការរក្សាសុវត្ថិភាពនៅលើបណ្តាញអ៊ុនធឺណិត ពិតជាមានការចាំបាច់ខ្លាំងណាស់ដែលមិនអាចខ្វះបាន។ មានការបាត់បង់ជាច្រើនប្រសិនបើយើងមិនបានប្រុងប្រយ័ត្នជាមួយការការពារសុវត្ថិភាព។ ហេដ្ឋារចនាសម្ព័ន្ធព័ត៌មានវិទ្យាគឺជាប្រព័ន្ធសុវត្ថិភាពស្នូលរបស់ស្ថាប័នទាំងមូលដែលពិភពលោកមិនអាចខ្វះបានសម្រាប់ជាមធ្យោបាយទំនាក់ទំនងស្ថេរភាព និងសុវត្ថិភាពនៃបណ្តាញពិតជាមានសារៈសំខាន់ណាស់សម្រាប់ប្រព័ន្ធទាំងមូល។ ការបង្កើតមូលដ្ឋានសុវត្ថិភាពសម្រាប់ហេដ្ឋារចនាសម្ព័ន្ធព័ត៌មានរបស់អង្គភាពអាចជួយការពារបណ្តាញ(Network)របស់អ្នកឱ្យមានសុវត្ថិភាពនិងជៀសផុតពីការលួចចូលរបស់ក្រុម (Hacker) ពីកន្លែងណាមួយ នៃប្រព័ន្ធកុំព្យូទ័រ។ ការពង្រឹងសុវត្ថិភាពប្រព័ន្ធបច្ចេកវិទ្យាព័ត៌មាន និង ការគ្រប់គ្រង ព្រឹត្តិការណ៍ (SIEM) គឺជាតួនាទីសំខាន់ក្នុងការការពារហេដ្ឋារចនាសម្ព័ន្ធបណ្តាញ។

គោលបំណង នៃការសិក្សានេះគឺដើម្បីកំណត់និងស្វែងយល់អំពីសុវត្ថិភាពប្រព័ន្ធបច្ចេកវិទ្យាព័ត៌មាននិងដំណើរការដែលត្រូវបានរៀបចំឡើងដើម្បីការពារកុំព្យូទ័របណ្តាញនិងទិន្នន័យពីការចូលដោយគ្មានការអនុញ្ញាត(hacker)ភាពងាយរងគ្រោះនិងការវាយប្រហារដែលត្រូវបានចែកចាយតាមរយៈអ៊ុនធឺណិត។ ជាពិសេសវាស្វែងរកចម្លើយ ចំពោះសំណួរដូចខាងក្រោម៖ (១) តើហេដ្ឋារចនាសម្ព័ន្ធបច្ចេកវិទ្យាព័ត៌មានវិទ្យាគឺជាអ្វី? (២) តើស្រទាប់សុវត្ថិភាពហេដ្ឋារចនាសម្ព័ន្ធបច្ចេកវិទ្យាព័ត៌មានវិទ្យាគឺជាអ្វី? (៣) តើសន្តិសុខហេដ្ឋារចនាសម្ព័ន្ធព័ត៌មានវិទ្យាមានគុណសម្បត្តិអ្វីខ្លះ? (៤) តើធ្វើដូចម្តេចដើម្បីដំឡើងប្រព័ន្ធសុវត្ថិភាពបច្ចេកវិទ្យាព័ត៌មាន និង ការគ្រប់គ្រងព្រឹត្តិការណ៍ (SIEM)?

មូលដ្ឋានសន្តិសុខសម្រាប់ហេដ្ឋារចនាសម្ព័ន្ធបច្ចេកវិទ្យាព័ត៌មានគឺជារឿងសំខាន់បំផុតសម្រាប់អាជីវកម្មរបស់អង្គភាពនីមួយៗដែលពឹងផ្អែកលើហេដ្ឋារចនាសម្ព័ន្ធផ្សេងៗគ្នា។ បញ្ហាប្រឈមនេះច្រើនតែបាត់បង់ទិន្នន័យទាក់ទងនឹងសុវត្ថិភាពហេដ្ឋារចនាសម្ព័ន្ធនិងការគ្រប់គ្រងហេដ្ឋារចនាសម្ព័ន្ធនៅមានកំរិតទាបនៅឡើយ។ បច្ចេកវិទ្យាថ្មីត្រូវការបន្ថែមផ្នែកសន្តិសុខបន្ថែមទៀតដូចជា Firewall, IDS/IPS, SIEM, ការវិភាគកំណត់ហេតុការពារការគំរាមកំហែងជាដើម។

ពាក្យគន្លឹះ: Security baseline, Firewall, Infrastructure, IDS, IPS, SIEM, SOC, and CIANA

ABSTRACT ENGLISH

The Internet has grown enormously over the last decade and has become ubiquitous. The Internet is a staple in our everyday lives. It is an excellent resource for connecting and sharing information. It is also full of unseen threats. Staying safe on the internet needs to be a conscience concern as we have much to lose if we don't exercise caution. IT infrastructure is a core asset to many organizations Internet is a global communication medium. The stability and security of the network is very important. A well establishes a secure infrastructure would help your network safe from intrusion from any source in any place. The protection of resources is an important aspect of any computer system. Harnessing and configuring Security Information and Event Management (SIEM) is an important role to safeguard network infrastructure.

The purpose of this study is to identify and understand the technologies and processes designed to protect computers, network and data from unauthorized access, vulnerabilities and attacks delivered via the Internet by the Cyber Criminal. Specifically, it sought to answer the following question: (1) What is IT Infrastructure Security? (2) What is the IT Infrastructure layer of security? (3) What are the advantages of IT Infrastructure Security? (4) How to implement for Security Information and Event Management (SIEM)?

Security baseline for IT infrastructure is the key business asset for organizations that depend on the geographically dispersed system, organizations risk being attacked and losing private information by breaches data in business activities. This challenge often data loss with regards to low infrastructure security and infrastructure management, when the increased cost in new hardware and technology needed to adds more part of security like firewalls, IDS/IPS, log analysts (SIEM), threat prevention.

Keywords: Security baseline, Firewall, Infrastructure, IDS, IPS, SIEM, SOC, and CIANA.

SUPERVISOR’S RESEARCH SUPERVISION STATEMENT

TO WHOM IT MAY CONCERN

Name of program: Master of Information Technology Engineering

Name of candidate: Chan Oeurn

Title of research report: Security Based Practices for an Organization IT infrastructure

This is to certify that the research carried out for the above titled master’s research report was completed by the above-named candidate under my direct supervision. This report material has not been used for any other degree. I played the following part in the preparation of this research report: Security Based Practices for an Organization IT infrastructure

Supervisor's name: Na Sambathchatovong

Supervisor’s signature:

Date:

CANDIDATE’S STATEMENT

TO WHOM IT MAY CONCERN

This is to certify that the research report that I, Chan Oeurn, hereby present entitled “Security baseline for IT infrastructure of Organization”. for the degree of Master of Science at the Royal University of Phnom Penh is entirely my own work and, furthermore, that it has not been used to fulfill the requirements of any other qualification in whole or in part, at this or any other University or equivalent institution.

No reference to, or quotation from, this document may be made without the written approval of the author.

Signed by Chan Oeurn:

Date:

Sign by Supervisor: Na Sambathchatovong

Supervisor’s signature:

Date:

ACKNOWLEDGMENTS

I would first like to pay my gratitude toward my supervisor, Mr. Na Sambathchatovong for all of his motivation, support and assistance getting through the process of earning master degree. You have helped in making this great experience for me during this research period to improve my new skill and more challenge with the time management.

I would also like to thank Dr. Khim Chamroeun, as offering me his assistance, experience and valuable time in critical stages of this project. I also want to thanks to my colleagues that provide me important information to complete this paper in appropriate order. I would like to thank Royal University of Phnom Penh of Teachers, Staffs and Managements for giving me chance to achieve of my goals in my study. I am gratefully indebted to him for his very valuable comments on this research report.

Finally, I must express my very profound gratitude to My Parents for providing me with unfailing support and continuous encouragement throughout my year of study and through the process of researching and writing this thesis. This accomplishment would not have been possible without them. knowledge and teach me all new things that I can improve in my daily job. Thank you.

Best regards,

CHAN OEURN

TABLE OF CONTENTS

	Page
Abstract in Khmer	(i)
Abstract in English	(ii)
Supervisor’s research supervision statement	(iii)
Candidate’s Statement	(iv)
Acknowledgements	(v)
Table of Contents	(vi)
List of Figures	(vii)
List of Abbreviation	(ix)
 CHAPTER 1 INTRODUCTION	 (1)
1.1 Background to the Study	(1)
1.2 Problem Statement	(1)
1.3 Aim and Objectives of the Study	(2)
1.4 Rationale of the Study	(2)
1.5 Limitation and Scope	(2)
 CHAPTER 2 LITURATURE REVIEW	 (3)
2.1 Definition of Infrastructure Security	(3)
2.2 History of Security	(3)
2.3 Hierarchical Design	(4)
2.3.1 Network Requirements	(4)
2.3.2 Network Layer	(5)
2.3.3 Comparing OSI and TCP/IP	(6)
2.4 Evolution of Security Threats	(7)
2.5 Infrastructure Security	(8)
2.6 Model of Security	(10)
2.6.1 Perimeter Security	(11)
2.6.2 Network Security	(12)
2.6.3 Endpoint Security	(18)
2.6.4 OS/Application Security	(20)
2.6.5 Data Security	(21)
 CHAPTER 3 PROPOSED SECURITY WITH SIEM AND VPN	 (23)
3.1 Current IT Infrastructure Security	(23)
3.2 New proposed with IT Infrastructure Security	(23)
3.3 Implementation	(24)
3.3.1 SIEM	(24)
3.3.2 Large Scale VPN (LSVPN)	(27)
3.3.3 Load balancer	(28)
 CHAPTER 4 RESULTS AND EVALUATION	 (30)
4.1 Security Enhancement	(30)
4.1.1 Security Posture	(30)
4.1.2 Security Incident review	(31)

CHAPTER 5 DISCUSSION	(33)
5.1 Conclusion	(33)
5.2 Future Work	(33)
REFERENCES	(34)
APPENDIXES	(35)
Appendix A: Installation and Configuration CentOS 7	(35)
Appendix B: Installation and Configuration Splunk	(36)

LIST OF FIGURES

Figure 1: General hierarchical design	(4)
Figure 2: ISO processing	(6)
Figure 3: Deference between ISO vs TCP/IP	(7)
Figure 4: Attack tool and technical knowledge required	(7)
Figure 5: Threats for Infrastructure	(8)
Figure 6: Infrastructure security	(10)
Figure 7: Layer of Security	(10)
Figure 8: Role of IDS and IPS	(13)
Figure 9: Next generation firewalls architecture	(14)
Figure 10: Virtual private network scenario	(17)
Figure 11: Devices security	(18)
Figure 12: Endpoint security management	(20)
Figure 13: Data Security management	(21)
Figure 14: Current Infrastructure Security for organization	(23)
Figure 15: New Infrastructure Security for organization	(24)
Figure 16: SIEM structure	(26)
Figure 17: LSVPN topology	(27)
Figure 18: Load balancer topology	(28)
Figure 19: Security Posture	(31)
Figure 20: Security Incident review	(31)
Figure 21: Security context	(32)
Figure 22: Security notable event	(32)

LIST OF ABBREVIATION

OSI	Open Systems Interconnection
TCP/IP	Transmission Control Protocol/Internet Protocol
IDS	Intrusion Detection Systems
IPS	Intrusion Prevention Systems
NGFW	Next Generation Firewall
SIEM	Security information and event management
SOC	Security operations center
CIANA	Confidentiality, Integrity, Availability, Non-repudiation and Authentication
NAC	Network access control
DOS	Denial-of-service
DDOS	Distributed Denial of Service
DMZ	Demilitarized Zone
SDN	Software-defined networking
NAT	Network address translation
VPN	Virtual private network
LSVPN	Large Scale Virtual private network
NIC	Network interface card
IP	Internet protocol
HTTPS	HyperText Transfer Protocol Secure
LAN	Local area network
WAN	Wide area network

CHAPTER 1

INTRODUCTION

1.1 Background of the Study

IT infrastructure defines the way in which devices are connected together to achieve end-to-end communications. Just as there are many sizes of networks, there are also many ways to build an infrastructure [1]. However, there are some standard designs that the network industry recommends to achieve networks that are available and secure. This chapter covers the basic operation of network infrastructures, including wired and wireless networks, network security, and network designs.

IT Infrastructure security is a global issue affecting international trading in the world. Infrastructure is the foundation or framework that supports a system or organization. In computing, information technology infrastructure is composed of physical and virtual resources that support the flow, storage, processing, and analysis of data. Infrastructure may be centralized within a data center, or it may be decentralized and spread across several data centers that are either controlled by the organization or by a third party, such as a colocation facility or cloud provider. A normal network comprises of routers, firewalls, switches, servers and workstations. A typical layout of network infrastructure devices is shown below.

Infrastructure security is the security provided to protect infrastructure, especially critical infrastructure, such as financial, airports, highways rail transport, hospitals, bridges, transport hubs, network communications, media, the electricity grid, dams, power plants, seaports, oil refineries, and water systems. Infrastructure security seeks to limit vulnerability of these structures and systems to sabotage, terrorism, and contamination. IT infrastructure security generally is comprised of five main goals are Confidentiality, Integrity, Availability, Non-repudiation and Authentication is call CIANA.

1.2 Problem Statement

This research is about security baseline for IT infrastructure of Organization. And by this study will list down the impacts of positive and negative in system.

Specifically, it seeks to answer the following questions:

1. How to protect external and internal threats?

2. What are IT Infrastructure layer of security?
3. How to implement for Security Information and Event Management (SIEM)?

1.3 Aim and Objectives of the Study

This study aims to achieve the following objectives:

1. To describe what is IT Infrastructure Security.
2. To describe Next Generation Firewall (NGFW).
3. To identify the advantages of IT Infrastructure Security.
4. To explain the ways to protect threats with IT Infrastructure Security.
5. To describe the ways implementation for security information and event management.

1.4 Rationale of the Study

In many organizations, security baseline for IT Infrastructure of Organization is the core of security for the whole system. So, the finding of this study will be very helpful and rationale to researcher in the following ways. Ensure that information is protected at an appropriate level and make all data is security by Infrastructure security.

1.5 Limitation and Scope

In the world the IT infrastructure security very big and use full. But for this research we have specific for network security is security aspects of networking and telecommunication protocols, including the security of routing, network security elements and specific cryptographic protocols used for network security and security information and event management (SIEM) focuses on log management [2].

CHAPTER 2

LITURATURE REVIEW

2.1 Definition of Infrastructure Security

Infrastructure security is the security provided to protect infrastructure, especially critical infrastructure, such as airports, highways rail transport, hospitals, bridges, transport hubs, network communications, media, the electricity grid, dams, power plants, seaports, oil refineries, and water systems. Infrastructure security seeks to limit vulnerability of these structures and systems to sabotage, terrorism, and contamination. Critical infrastructures naturally utilize information technology as this capability has become more and more available [3]. As a result, they have become highly interconnected, and interdependent. Intrusions and disruptions in one infrastructure might provoke unexpected failures to others. How to handle interdependencies becomes an important problem. The most recent example of vulnerable infrastructure was the electrical grid in 2003, when Northeastern American areas experienced a power outage that appears to have originated in the Midwest, and possibly from a tree branch.

2.2 History of Security

In 1969, the Internet started with four interconnected computers in U.S. and was known as ARPAnet, a project funded by the Advanced Research Projects Agency of the U.S. Department of Defense [4]. Today, it is made up of hundreds of millions of hosts and hundreds of thousands of networks all over the world, carrying various kinds of information and services, such as electronic mail, World Wide Web, and file transfer. Private security is not a new concept. Security forces existed long before a paid police force. Private security has a long history starting in medieval times when knights protected lords and ladies. In the colonies all able-bodied men were to stand a citizen's night watch to protect the community from invasion and fire. ADT (American district telegraph company) was formed in 1874. It is still today one of the largest alarm monitoring companies in the country:

- 1993 – Cisco GRE Tunnels
- 1996 – Site-to-Site VPNs
- 1999 – SSH
- 2000 – MPLS VPNs
- 2001 – Remote-Access IPsec VPN
- 2002 – Dynamic Multipoint VPN

- 2005 – SSL VPN
- 2009 – Group Encrypted Transport VPN (GET VPN)

2.3 Hierarchical Design

Typical enterprise hierarchical LAN campus network design includes the following three layers access layer provides workgroup user access to the network and distribution layer provides policy-based connectivity and controls the boundary between the access and core layers and core layer are provides fast transport between distribution switches within the enterprise campus

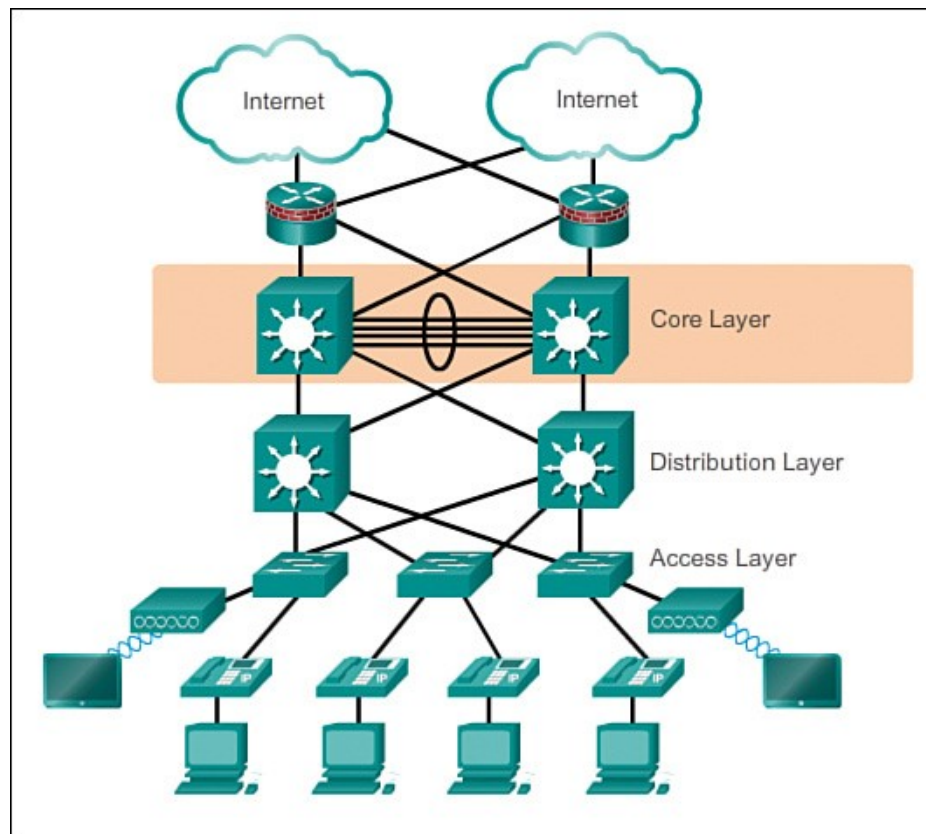


Figure 1: General hierarchical design

2.3.1 Network Requirements

When discussing network design, it is useful to categorize networks based on the number of devices serviced as small network provides services for up to 200 devices, medium-size network provides services for 200 to 1,000 devices and large network are provides services for 1,000 devices up to. Network designs vary depending on the size and requirements of the organizations. For example, the networking infrastructure needs of a small organization with fewer devices will be less complex than the infrastructure of a large organization with a significant number of devices and connections.

2.3.2 Network Layer

The International Standards Organization (ISO) developed the Open Systems Interconnect (OSI) model in 1981. It consists of seven functional layers that provide the basis for communication among computers over networks, as described in the table below. You can easily remember them using the mnemonic phrase “All people seem to need data processing.” Understanding this model will help you build a strong network, troubleshoot problems, develop effective applications and evaluate third-party products.

Layer	Function	Protocols or Standards
Layer 7: Application	Provides services such as e-mail, file transfers and file servers	HTTP, FTP, TFTP, DNS, SMTP, SFTP, SNMP, RLogin, BootP, MIME
Layer 6: Presentation	Provides encryption, code conversion and data formatting	MPEG, JPEG, TIFF
Layer 5: Session	Negotiates and establishes a connection with another computer	SQL, X- Window, ASP, DNA, SCP, NFS, RPC
Layer 4: Transport	Supports end-to-end delivery of data	TCP, UDP, SPX
Layer 3: Network	Performs packet routing	IP, OSPF, ICMP, RIP, ARP, RARP
Layer 2: Data link	Provides error checking and transfer of message frames	Ethernet, Token Ring, 802.11
Layer 1: Physical	Physically interfaces with transmission medium and sends data over the network	EIA RS-232, EIA RS-449, IEEE, 802

Open System Interconnection (OSI) is a reference model that defines the communication of data over the network. It is a framework that portrays the flow of data from one device to another over the network. The OSI model classifies the communication between two end-points into seven different groups of layers. The logic behind this division is that the communicating user provides functions of each of the

seven layers. The communication between two users occurs as a downward flow of data through the layers of the source computer. Then, it traverses across the network and flows upwards through the layers of the destination computer. Features of OSI model include. Provides a clear understanding regarding the communication over the network. Displays the working of software and hardware. Helps the users in understanding newer technologies. Easy comparison between the functional relationships between different networks. The OSI model has a set of protocols that allows the object on one host to communicate with the corresponding object on another host.

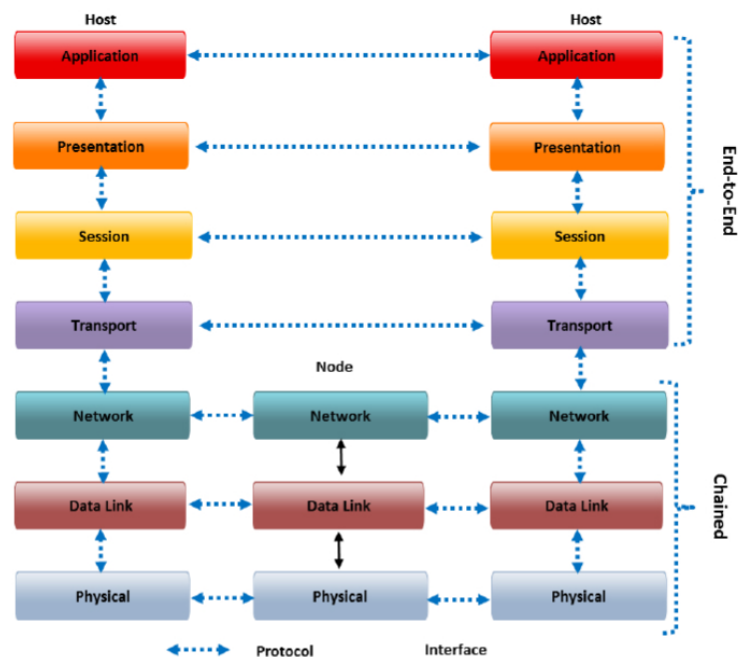


Figure 2: ISO processing

2.3.3 Comparing OSI and TCP/IP

OSI model is the main aim behind implementing the OSI model is to standardize and ease the communication between the communicating parties using certain standard protocols. It generalizes the communication between the computers in terms of layers. The OSI model has seven layers. In this model, a layer serves the layer above it that brings to a conclusion the working of each layer depends on the layers below it.

TCP/IP model is remains as the basic protocol for communication. The TCP/IP protocol finds its application either in an intranet or in an extranet. TCP/IP consists of four layers, out of which the upper layers manage the assembling of the packets in the

original message and the lower layers manage the address part of each packet and forwards it to the right destination.

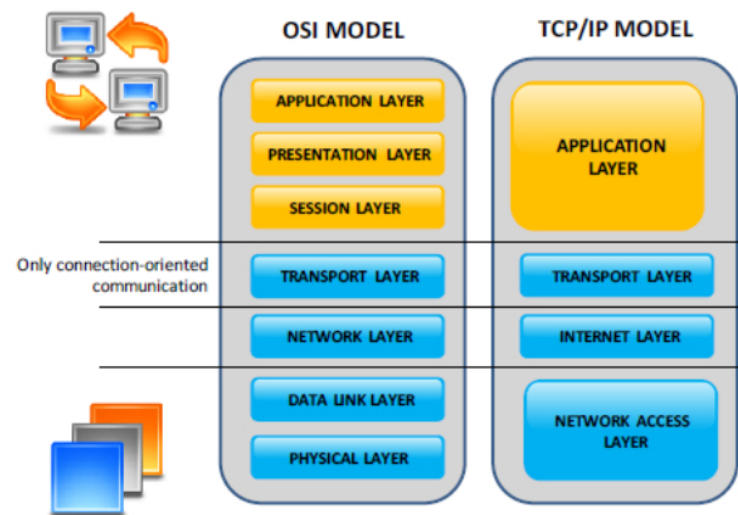


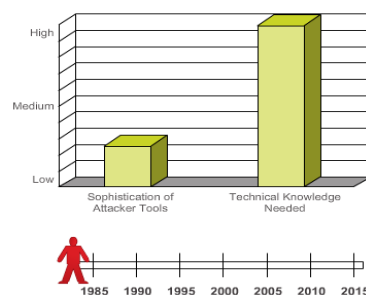
Figure 3: Deference between ISO vs TCP/IP

2.4 Evolution of Security Threats

The early users of the Internet did not spend much time thinking about whether or not their online activities presented a threat to the network or to their own data. Today, the Internet is a very different network compared to its beginnings. More people rely on the network for their personal, financial, and business needs

- 1989 – AT&T Bell Labs Stateful Firewall
- 1991 – DEC SEAL Application Layer Firewall
- 1994 – Check Point Firewall
- 1997 – RealSecure IDS
- 1999 – First IPS
- 2006 – Cisco Zone-Based Policy Firewall
- 2010 – Evolution of Network Security Tools

Attack Tools Sophistication Vs. Technical Knowledge Required



Attack Tools Sophistication Vs. Technical Knowledge Required

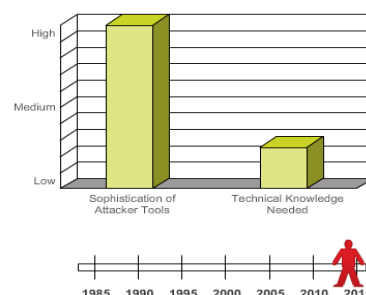


Figure 4: Attack tool and technical knowledge required

IT infrastructure have two threats, External and Internal threats. External threat is almost always malicious, with data theft, vandalism and disruption of services all possible goals. Internal threats can be equally vicious and may also include blackmail or other illicit activities. Internal threats, however, are not always malicious. External threats are almost always malicious, with data theft, vandalism and disruption of services all possible goals. Internal threats can be equally vicious and may also include blackmail or other illicit activities. Internal threats, however, are not always malicious.

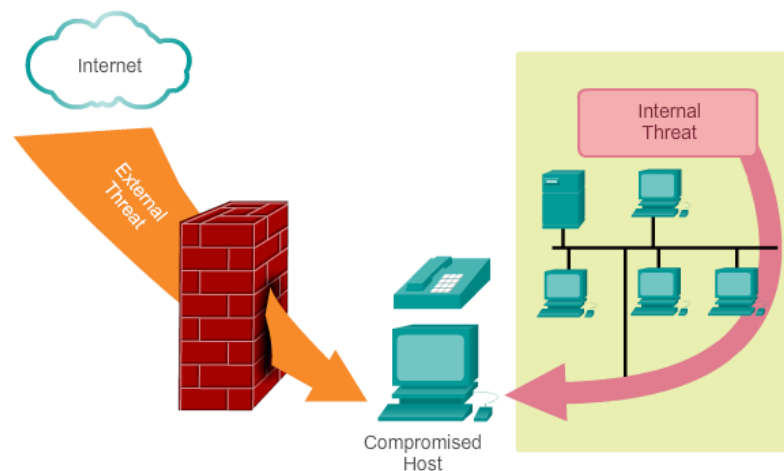


Figure 5: Threats for Infrastructure

2.5 Infrastructure Security

What is IT Infrastructure Security?

The network security components include enforcement of Authentication and Integrity, Confidentiality, Access Control and Audits is performed by network security components consisting of Network Management elements in form of Proxy agents (for SNMP, DHCP or DNS), Packet Filtering firewalls to create a set of rules to either accept or reject network traffic performing IP routing or be the destination for the traffic, Cryptography and SIEM log management for analysis [5]. These components are typically off-the-shelf and the model is associated with network quality attributes such as device integration, maintainability, reliability, performance, modifiability. The network security architecture is dependent on different types of off-the-shelf components; hence the architectural model becomes a highly critical aspect of the network security policy design process.

The security architecture should be implemented to work on the premise that in case the first level attack is successful and able to breach the initial defenses, the internal network components should be able to block any subsequent stages of that attack. This is a clear requirement for an intrusion which is a zero day or near zero-day attack. Another feature of the model is being formal. This allows the model to be analyzed logically in an auto computational process, instead of being manually reviewed which is prone to human errors. Another feature is being hierarchical and allowing the configuration to be synthesized directly from the model and be scalable. This provides the ability to have yet-to-be developed low-level components in the form of black box sub components in high-level design model. These low-level systems can be commissioned independently in a top-down design development approach. A bottom-up approach can also be taken up, which begins with process at low-level to high-level functionalities using pre-commissioned low-level black boxes. For example, a network firewall can be modeled by utilizing proxy agent black boxes and packet-filtering black boxes. Then a firewall black-box could be used as the high-level component of the security design integrating with other high-level components and elements like trust management, certificate management or even IOS version control. The module design breaks the high-level main design objective into smaller repeatable blocks. For example, when design a huge network setup having several smaller sites, having the same design and similar deployment process for each site which includes common set of security controls like ACL or firewall rules. Then any change across all the sites can be applied smoothly without any major rollout changes. Thus, the Architectural Foundation model consists of the following two areas as Network Components security configurations for security devices such as Network Firewalls

- Application Firewall, VPN Gateways, Packet Filters and Caching devices
- Perimeter devices Routers, Load Balancers
- Network devices like Switches

Data Flow which represents communication and traffic flow between the different components in the model and captured using tools like NetFlow analyzer or Wireshark.

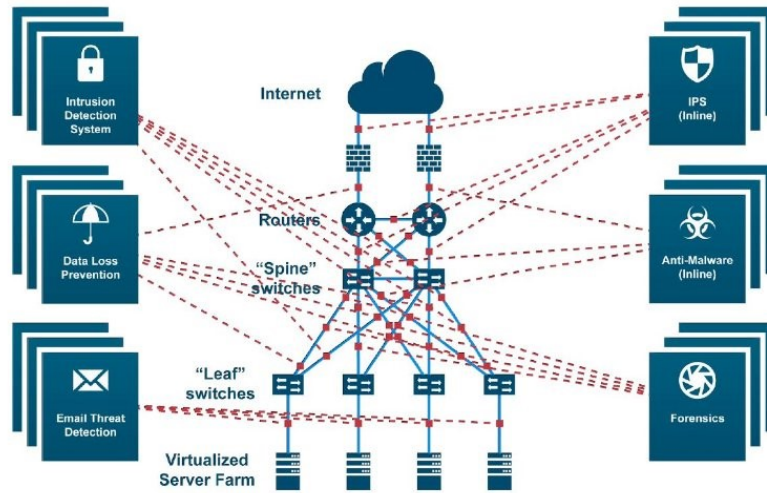


Figure 6: Infrastructure security

2.6 Security Model

It is defense in depth to follow this rule while designing and implementing any security system or model. This security model is represented in the figure below. This model consists of 5 layers of security and each layer is described in detail in this paper. Most of us don't work for organizations with budgets for procurement of security equipment or systems (or security personnel). In this context, I have tried to implement this Layered Security Model with the help of tools/technologies available free on the Internet [6]. These tools perform data collection, analysis, reporting and generation of alarms.



Figure 7: Layer of Security

What are IT Infrastructure layer of security?

The five key layers of the security model are:

- Layer1: Perimeter Security
- Layer2: Network Security
- Layer3: Endpoint Security
- Layer4: OS/Application Security
- Layer5: Data Security

The Infrastructure security not only five layer all so must be need mission critical assets and security operation center.

2.6.1 Perimeter Security

There are multiple ways to clarify and secure your network perimeter. But since every network is different, the exact strategies for protecting it is beyond the scope of this article. However, at the risk of oversimplifying, the process and tools outlined below will give you an understanding of what safeguarding your network edge will look like [7]. The Four-Step Process for Protecting your Perimeter:

1. Identify the perimeter: document all devices that have access to your network
2. Learn what data flows through the perimeter
3. Secure the devices that form the perimeter
4. Guard the data that flows through the perimeter

There are many technologies available to you to help secure your network perimeter:

- Firewalls
- Anti-virus / Anti-malware on those firewalls
- Intrusion Detection software
- Intrusion Prevention Software
- Data Loss Prevention: Ensuring certain data doesn't leave your network
- Secure De-Militarized Zone (DMZ) a more secure network configuration.

2.6.2 Network Security

Switches generally have a more intelligent role than hubs. Strands of LANs, are usually connected using switches. Mainly working at the Data Link layer, they read the packet headers and process the packets appropriately. Generally, switches can read the hardware addresses of incoming packets to transmit them to the appropriate destination.

Routers help transmit packets to their destinations by charting a path through the sea of interconnected network devices. They remove the packets from the incoming frames, analyze them individually and assign IP addresses. Routers normally work at the Network layer of the OSI model.

Gateways normally work at the Transport and Session layers of the OSI model. At the Transport layer and above, there are numerous protocols and standards from different vendors; gateways are used to deal with them.

Intrusion is a set of actions aimed at compromising the basic network security goals like confidentiality, integrity, availability of a computing/networking resource. The main difference being that firewall preforms actions such as blocking and filtering of traffic while and IPS/IDS detects and alert a system administrator or prevent the attack as per configuration.

Firewall is to allows traffic based on set of rules configured. It relies on source, the destination addresses, and the ports. A firewall can deny any traffic that does not meet the specific criteria.

Intrusion detection systems (IDS) are basically identifying intrusion threats, attacks and malicious activities in a network and generate alerts. The limitation of IDS is they cannot resolve network attacks; it passes in network for only watches network traffic like packet sniffing. The IDS are basically analyses the copied packets on the network segment for detecting attacks or attack has already taken place, this to alert network admin for what is happening in network.

Intrusion prevention system (IPS) is the process of both detecting intrusion activities or threats and managing responsive actions on those detected intrusions and threats throughout the network. IPS are monitoring real time packet traffic with malicious activities or which match specific profiles and will trigger the generation of alerts and it can drop, block that traffic in real time pass through in network. The mainly IPS counter

measures is to stop an attack in progress. “In simple terms, IDS may be perfectly suited for network attack monitoring and for alerting administrators of emerging threats. But its speed, performance and passive limitations have opened the door for IPS to challenge it as the proactive defense weapon of choice.” Furth more, below table enumerates the difference between Firewall, IPS and IDS in detail

Data log analysis: The IDS and IPS devices are gives a comprehensive logs and data collection, its without actionable alerts, the data gathered from these devices and sensors throughout the network can be used for event correlation and network forensics in a post-attack scenario. This type of data is critical for analysis during and after attacks and can help for organization with both incident response and compliance audits.

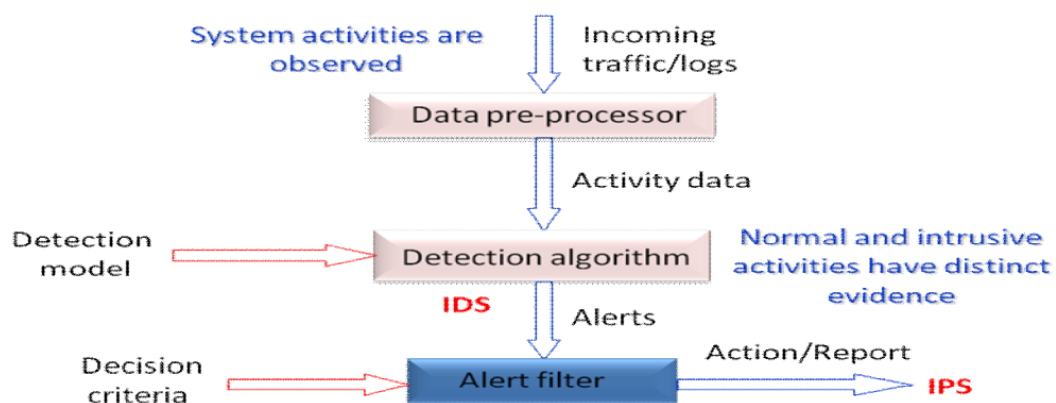


Figure 8: Role of IDS and IPS

What is a Next Generation Firewall (NGFW)?

Next Generation Firewalls: is a traditional firewall is limited to functions such as packet filtering, network- and port-address translations (NAT) and VPN's. It makes its decisions based on ports, protocols and IP addresses. Nowadays it's no longer practical nor reliable to implement security policies in such an inflexible and non-transparent way. A new approach was needed and NGFWs provide this approach by adding more context to security policies. Context-based systems are designed to use information like location, identity, time, etc... in an intelligent way with the purpose of making more effective security decisions. Also distinguish themselves from traditional firewalls by adding features such as URL filtering, anti-virus/anti-malware, Intrusion Prevention Systems (IPS) and more. Instead of using several different point solutions, a NGFW greatly

simplifies and improves the effectiveness of implementing security policies in an increasingly complex computing world.

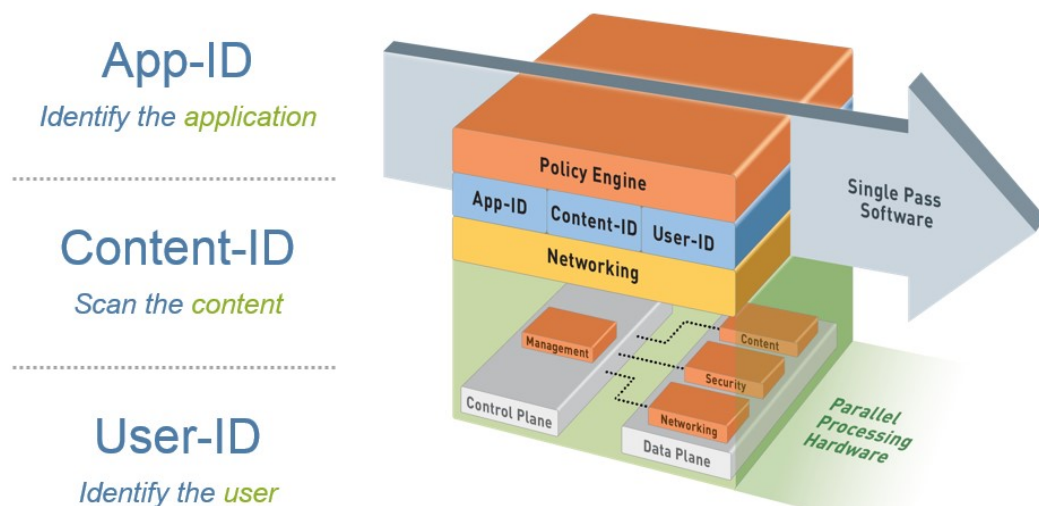


Figure 9: next generation firewalls architecture

Network access control (NAC) involves restricting the availability of network resources to endpoint devices that comply with your security policy. Some NAC solutions can automatically fix non-compliant nodes to ensure it is secure before access is allowed. NAC is most useful when the user environment is fairly static and can be rigidly controlled, such as enterprises and government agencies. It can be less practical in settings with a diverse set of users and devices that are frequently changing, which are common in the education and healthcare sectors.

Web filters are solutions that by preventing users' browsers from loading certain pages from particular websites. There are different web filters designed for individual, family, institutional and enterprise use.

Proxy servers act as negotiators for requests from client software seeking resources from other servers. A client connects to the proxy server, requesting some service (for example, a website); the proxy server evaluates the request and then allows or denies it. In organizations, proxy servers are usually used for traffic filtering and performance improvement.

Anti-DDoS devices detect distributed denial of service (DDoS) attacks in their early stages, absorb the volume of traffic and identify the source of the attack.

Load balancers are physical units that direct computers to individual servers in a network based on factors such as server processor utilization, number of connections to a server or overall server performance. Organizations use load balancers to minimize the chance that any particular server will be overwhelmed and to optimize the bandwidth available to each computer in the network.

Spam filters detect unwanted email and prevent it from getting to a user's mailbox. Spam filters judge emails based on policies or patterns designed by an organization or vendor. More sophisticated filters use a heuristic approach that attempts to identify spam through suspicious word patterns or word frequency.

Types of Network Segments Network segments can be classified into the following categories:

Public networks allow accessibility to everyone. The internet is a perfect example of a public network. There is a huge amount of trivial and unsecured data on public networks. Security controls on these networks are weak.

Semi-private networks sit between public networks and private networks. From a security standpoint, a semi-private network may carry confidential information but under some regulations.

Private networks are organizational networks that handle confidential and propriety data. Each organization can own one or more private networks. If the organization is spread over vast geographical distances, the private networks at each location may be interconnected through the internet or other public networks.

Demilitarized zone (DMZ) is a noncritical yet secure region at the periphery of a private network, separated from the public network by a firewall; it might also be separated from the private network by a second firewall. Organizations often use a DMZ as an area where they can place a public server for access by people they might not trust. By isolating a server in a DMZ, you can hide or remove access to other areas of your network. You can still access the server using your network, but others aren't able to access further network resources.

Software-defined networking (SDN) is a relatively recent trend that can be useful both in placing security devices and in segmenting the network. Essentially, in an SDN, the entire network is virtualized, which enables relatively easy segmentation of the network. It also allows administrators to place virtualized security devices wherever they want.

Network Address Translation is (NAT) enables organizations to compensate for the address deficiency of IPv4 networking. NAT translates private addresses (internal to a particular organization) into routable addresses on public networks such as the internet. In particular, NAT is a method of connecting multiple computers to the internet (or any other IP network) using one IP address. NAT complements firewalls to provide an extra measure of security for an organization's internal network. Usually, hosts from inside the protected networks, which have private addresses, are able to communicate with the outside world, but systems that are located outside the protected network have to go through the NAT boxes to reach internal networks. Moreover, NAT enables an organization to use fewer IP addresses, which helps confusing attackers about which particular host they are targeting.

Centralized Log Analysis is record suspicious logins and other computer events and look for anomalies. This best practice will help you reconstruct what happened during an attack so you can take steps to improve your threat detection process and quickly block attacks in the future. However, remember that attackers are clever and will try to avoid detection and logging. They will attack a sacrificial computer, perform different actions and monitor what happens in order to learn how your systems work and what thresholds they need to stay below to avoid triggering alerts.

Web Domain Whitelisting for All Domains is limiting users to browsing only the websites you've explicitly approved helps in two ways. First, it limits your attack surface. If users cannot go to untrusted websites, they are less vulnerable. It's a solid solution for stopping initial access via the web. Second, whitelisting limits hackers' options for communication after they compromise a system. The hacker must use a different protocol, compromise an upstream router, or directly attack the whitelisting mechanism to communicate. Web domain whitelisting can be implemented using a web filter that can make web access policies and perform web site monitoring.

Insider Threats to deal with insider threats, you need both prevention and detection strategies. The most important preventive measure is to establish and enforce the least-privilege principle for access management and access control. Giving users the least amount of access, they need to do their jobs enhances data security, because it limits what they can accidentally or deliberately access and ensures that if their password is compromised, the hacker doesn't have all keys to the kingdom. Other preventative measures include system hardening, anti-sniffing networks and strong authentication. Detection strategies include monitoring users and networks and using both network- and host-based intrusion detection systems, which are typically based on signatures, anomalies, behavior or heuristics. End users also need to be trained in how to deal with the security threats they face, such as phishing emails and attachments. The best security in the world can be undermined by end users who fail to follow security policies. However, they cannot really be expected to follow those policies without adequate training.

VPNs is a virtual private network (VPN) is a secure private network connection across a public network. For example, VPNs can be used to connect LANs together across the internet. With a VPN, the remote end appears to be connected to the network as if it were connected locally. A VPN requires either special hardware or VPN software to be installed on servers and workstations. VPNs typically use a tunneling protocol, such as Layer 2 Tunneling Protocol, IPsec or Point-to-Point Tunneling Protocol (PPTP). To improve security, VPNs usually encrypt data, which can make them slower than normal network environments.

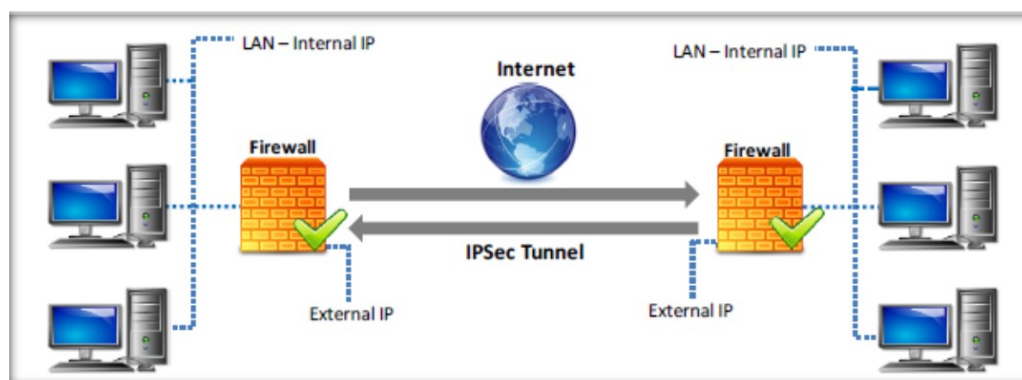


Figure 10: Virtual private network scenario

Block IP address The IDS or firewall can block the IP address from which the attack originated. This option is very effective against spam and denial-of-service attacks. However, some attackers spoof the source IP address during attacks, so the wrong address will be blocked.

Multiple Vendors In addition to diversity of controls, you should strive for diversity of vendors. For example, to defend against malware, you should have antimalware software on each of your computers, as well as on the network and at the firewall — and use software from different vendors for each of these places. Because each vendor uses the same malware detection algorithms in all its products, if your workstation, network and firewall antimalware solutions all come from vendor A, then anything missed by one product will be missed by all three. The best approach is to use vendor A for the firewall antimalware, vendor B for the network solution, and vendor C to protect individual computers. The probability of all three products, created by different vendors and using different detection algorithms, missing a specific piece of malware is far lower than any one of them alone missing it.

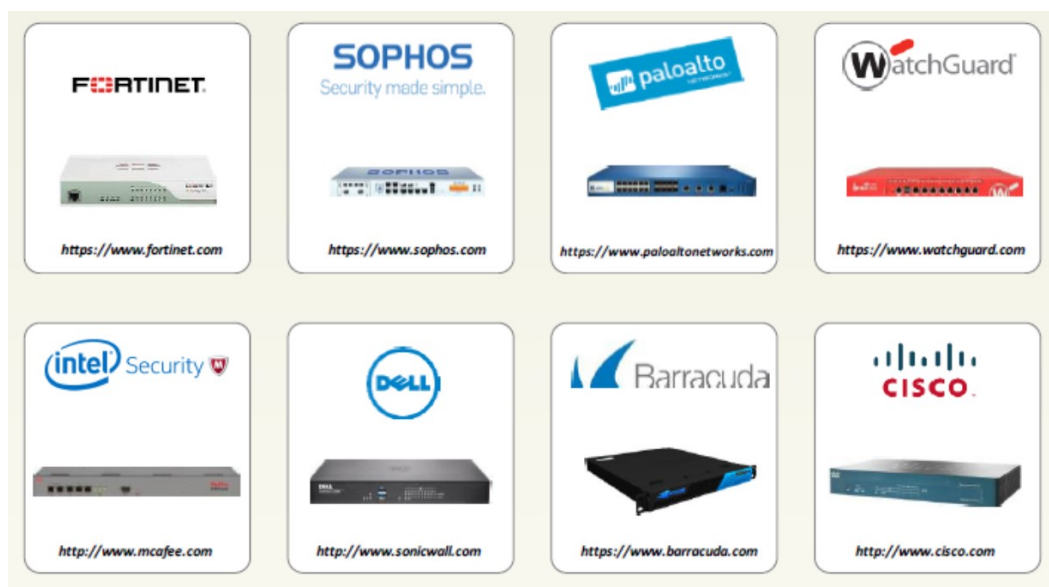


Figure 11: Devices security

2.6.3 Endpoint Security

What is Endpoint Security?

Endpoint Security or Endpoint Protection is a centralized approach to protecting all endpoints - servers, desktops, laptops, smartphones and other IoT devices - connected to the corporate IT network from cyber threats. This methodology enables efficient, effective and easier security management. Some vendors offer Endpoint Security systems that includes antivirus, firewall and other high defined security software. When any device-smartphone, laptop, tab etc- is connected remotely to a network, the endpoint thus created would provide an entry point for threats and malware. Endpoint security management is all about adequately securing such endpoints and thereby securing a network by blocking access attempts and such risky activities at endpoints. Endpoint security systems are a must in today's threat landscape. As more enterprises adopt practices like BYOD and also as incidences of mobile threats are consistently on the rise, endpoint security becomes highly relevant. Employees today connect to company networks using their laptops or mobile devices, from their homes and also while on the move. In this scenario, when security perimeters tend to be undefinable and ever-shifting, a centralized security solution won't be adequate. It's here that security endpoints come in, supplementing centralized security measures with additional layers of protection at endpoints, which are not just entry points for threats and attacks, but points of egress for sensitive data (corporate and personal) as well. Companies need to ensure that endpoint devices meet security standards; this has to be ascertained before such devices are granted network access. Endpoint security helps enterprises maintain greater control over all access points and also helps block threats and access attempts effectively. Security endpoint tools also help monitor for, detect and block malicious activities. Endpoint security systems typically consist of a centrally located security software (which is located on a centrally managed server or gateway within the network) plus the client software that's installed on each endpoint or endpoint device. What is the difference between Endpoint Security and Antivirus Software?

It's to be understood that endpoint security software happens to be basically different from the antivirus software. In the case of endpoint security software, it's not an individual device that's protected; it's the network as a whole that is secured. The endpoints or endpoint devices, on the other hand, bear some amount of responsibility for their own security as well. This means that even when there is an endpoint protection software to safeguard a network, it's always necessary also to protect endpoint devices like laptops, smartphones etc with endpoint security antivirus or antimalware tools.

Comodo's free endpoint antivirus software is capable of protecting your network with anti-spyware, anti-spam, and virus protection, which can lessen slowdowns of the system and offer customized options.



Figure 12: Endpoint security management

2.6.4 OS/Application Security

Application security encompasses measures taken to improve the security of an application often by finding, fixing and preventing security vulnerabilities. Different techniques are used to surface such security vulnerabilities at different stages of an application's lifecycle such as design, development, deployment, upgrade, maintenance. Different techniques will find different subsets of the security vulnerabilities lurking in an application and are most effective at different times in the software lifecycle. They each represent different tradeoffs of time, effort, cost and vulnerabilities found. Whitebox security review, or code review. This is a security engineer deeply understanding the application through manually reviewing the source code and noticing security flaws. Through comprehension of the application vulnerabilities unique to the application can be found. Blackbox security audit this is only through use of an application testing it for security vulnerabilities, no source code required. Design review before code is written working through a threat model of the application. Sometimes alongside a spec or design document. Tooling there exist many automated tools that test for security flaws, often with a higher false positive rate than having a human involved. Static application security

testing (SAST) is a set of technologies designed to analyze application source code, byte code and binaries for coding and design conditions that are indicative of security vulnerabilities. SAST solutions analyze an application from the “inside out” in a nonrunning state.

2.6.5 Data Security

Both data security and data privacy are strongly interconnected to each other but are not the same. Understanding the differences of data security vs. data privacy will help you to understand better how each of them works and how they complement each other. In short, data privacy is all about authorized access, concerning who has it and who defines it. Data security, on the other hand, is about securing data against unauthorized access. In other words, data security is about the technical implementation of what data privacy dictates. These simple differences are significant because they have implications for privacy and cybersecurity, which, in turn, have enormous consequences on business, politics, and society as a whole. Industries that are subject to compliance standards have to adhere to privacy laws and other legal implications.

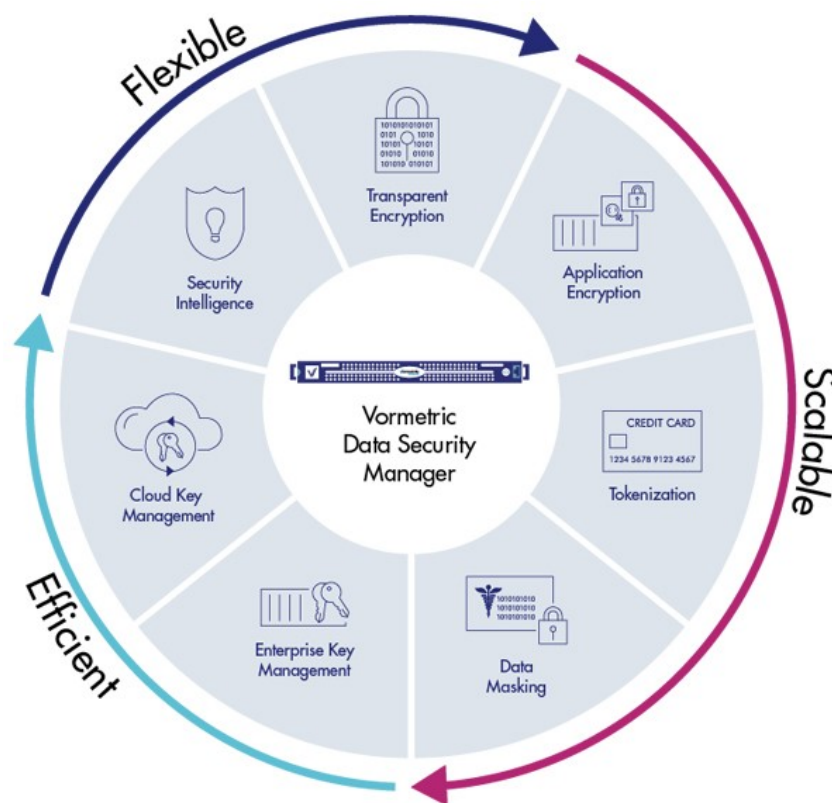


Figure 13: Data Security management

➤ **Advantages of IT Infrastructure Security**

Advantages IT Infrastructure security are securing and protecting your clients' networks from the myriad of threats on the cybe protection from malicious attacks on your network. Deletion or guaranteeing malicious elements within a preexisting network prevents users from unauthorized access to the network, deny's programs from certain resources that could be infected. securing confidential information.

CHAPTER 3

PROPOSED SECURITY WITH SIEM

3.1 Current IT Infrastructure Security

The proposed NonTax system architecture includes the separate environments for the application, database and domain/web servers in line with an architecture model, including the Production environment is a primary environment of system where locate application, database and domain/web servers for productive business processing. No development or testing activities are permitted in this environment and formal change control procedures are implemented to ensure only fully tested, approved, changes to configuration and programming objects are imported. The system is implemented at one Data Center with IT Infrastructure security as below:

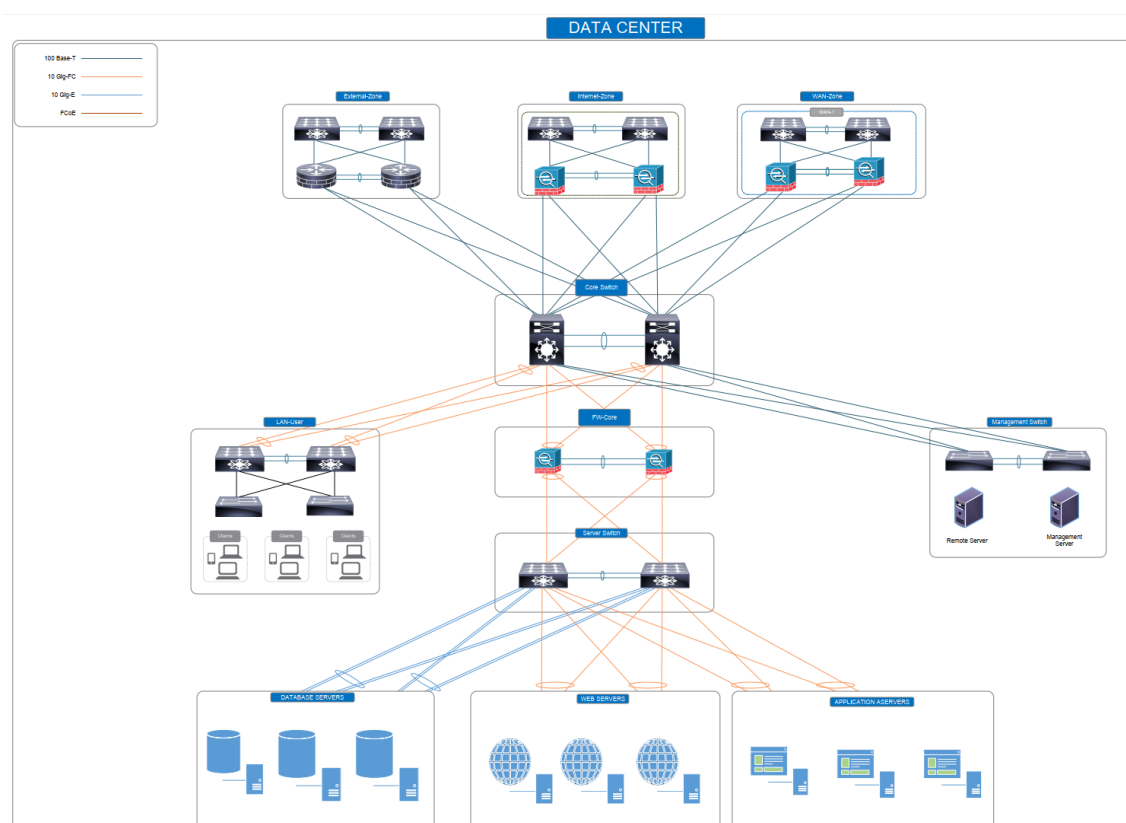


Figure 14: Current Infrastructure Security for organization

3.2 New proposed with IT Infrastructure Security

The high security for the IT Infrastructure system is provided by integration of technology at different layers such as encrypted communication, application gateway, firewall, IPS, antivirus, antispam, web filtering. The high availability of the system is

provided by fully redundant with hot swappable components of hardware components. Most security programs operate on a micro scale, addressing smaller threats but missing the bigger picture of cyber threats. An Intrusion Detection System (IDS) alone can seldom do more than monitor packets and IP addresses. Likewise, your service logs only show user sessions and configuration changes. SIEM puts these systems and others like it together to provide a complete overview of any security incident through real-time monitoring and the analysis of event logs. The new proposal for Infrastructure as below:

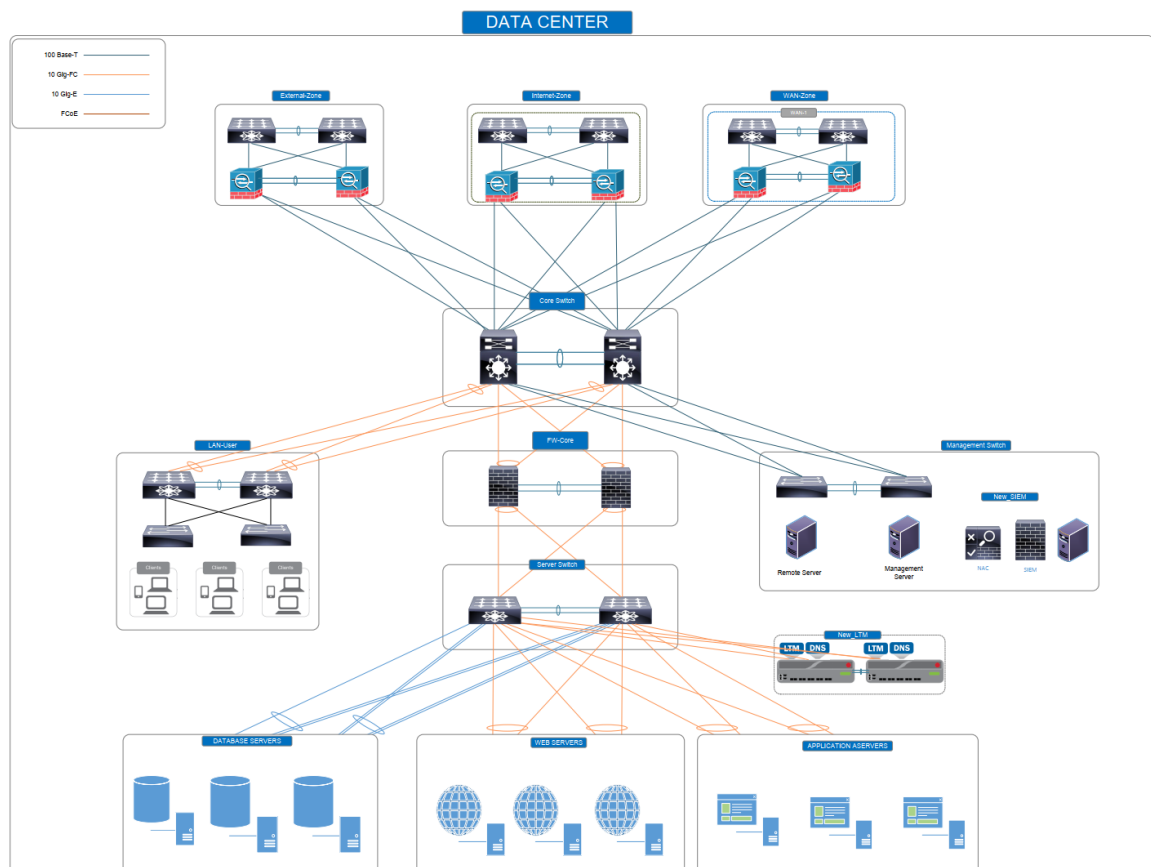


Figure 15: New Infrastructure Security for organization

3.3 Implementation

3.3.1 SIEM

SIEM tools are an important part of the data security ecosystem: they aggregate data from multiple systems and analyze that data to catch abnormal behavior or potential cyberattacks. SIEM tools provide a central place to collect events and alerts – but can be expensive, resource intensive, and customers report that it is often difficult to resolve problems with SIEM data.

What is SIEM?

Security Information and Event Management (SIEM) is a software solution that aggregates and analyzes activity from many different resources across your entire IT infrastructure. SIEM collects security data from network devices, servers, domain controllers, and more. SIEM stores, normalizes, aggregates, and applies analytics to that data to discover trends, detect threats, and enable organizations to investigate any alerts.

How Does SIEM Work?

SIEM provides two primary capabilities to an incident response team. Reporting and forensics about security incidents Alerts based on analytics that match a certain rule set, indicating a security issue. At its core, SIEM is a data aggregator, search, and reporting system. SIEM gathers immense amounts of data from your entire networked environment, consolidates and makes that data human accessible. With the data categorized and laid out at your fingertips, you can research data security breaches with as much detail as needed.

Gartner identifies three critical capabilities for SIEM (threat detection, investigation and time to respond) — there are other features and functionality benefits of SIEM include:

- Security monitoring
- Increased efficiency
- Preventing potential security threats
- Reducing the impact of security breaches
- Reducing costs
- Better reporting, log analysis and retention
- IT compliance

The following illustration shows the software components, log files, and network protocols in a typical SIEM deployment.

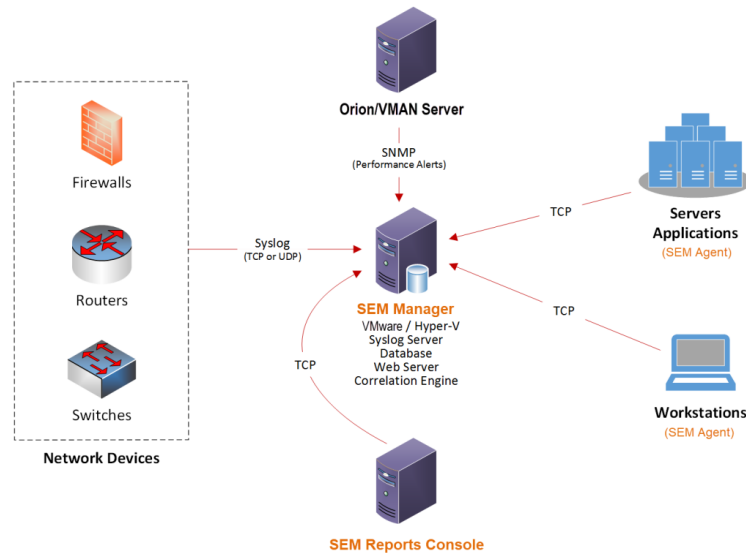


Figure 16: SIEM structure

Originally, SIEM was sold as a physical appliance that you deployed on your network. Today, the SIEM Manager is the virtual image of a Linux-based appliance. The SIEM Manager VM (virtual machine) can be easily deployed on a host computer running a VMware® or Microsoft® hypervisor. The SIEM Manager collects and processes log and event information. It includes the following systems and services:

- Hardened Linux® OS
- Syslog Server and SNMP Trap Receiver
- High compression, search-optimized database
- Web server
- Correlation engine

The following requirements represent the basic building block of a Splunk Enterprise deployment.

- Intel x86 64-bit chip architecture
- 12 CPU cores at 2Ghz or greater speed per core
- 12 GB RAM
- Standard 1Gb Ethernet NIC, optional second NIC for a management network
- Standard 64-bit Linux or Windows distribution

The following deployment example uses one central syslog server to collect log data from your network devices in a local network. In this deployment, network devices

use TCP or UDP to send syslog data to the SIEM Manager's syslog server, whereas SIEM Agents running on workstations and servers just use TCP to push log data to the SIEM Manager. The syslog server receives logs on port 8000 and saves the data in the SIEM Manager /var/log file partition. Log file names vary based on the target facility configured on the network device. The following diagram shows four SIEM VM instances. One each for the SEM Manager, syslog collection, the normalized data store, and an optional original data store.

3.3.2 Large Scale VPN (LSVPN)

The Global Protect Large Scale VPN (LSVPN) feature on the Palo Alto Networks next generation firewall simplifies the deployment of traditional hub and spoke VPNs, enabling you to quickly deploy enterprise networks with several branch offices with a minimum amount of configuration required on the remote satellites. This solution uses certificates for firewall authentication and IPsec to secure data. LSVPN enables site-to-site VPNs between Palo Alto Networks firewalls. To set up a site-to-site VPN between a Palo Alto Networks firewall and another device, see VPNs. The following topics describe the LSVPN components and how to set them up to enable site-to-site VPN services between Palo Alto Networks firewalls. The following diagram illustrates how the Global Protect LSVPN components work together.

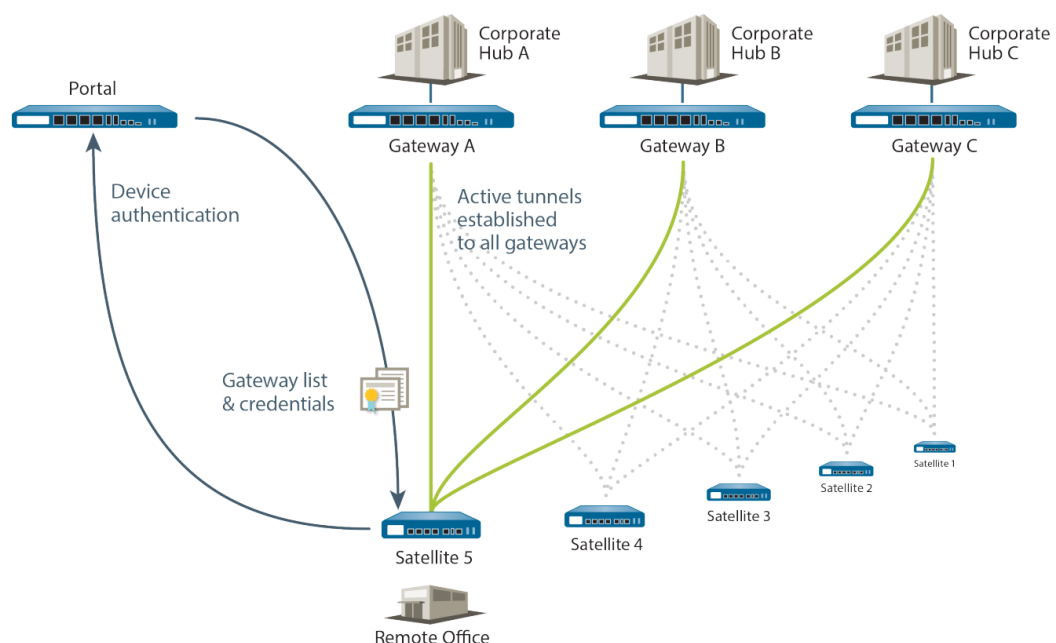


Figure 17: LSVPN topology

3.3.3 Load balancer

The load balancer is a device that acts as a reverse proxy and distributes network or application traffic across a number of servers. Load balancers are used to increase capacity (concurrent users) and reliability of applications. They improve the overall performance of applications by decreasing the burden on servers associated with managing and maintaining application and network sessions, as well as by performing application-specific tasks. Load balancers are generally grouped into two categories: Layer 4 and Layer 7. Layer 4 load balancers act upon data found in network and transport layer protocols (IP, TCP, FTP, UDP). Layer 7 load balancers distribute requests based upon data found in application layer protocols such as HTTP and HTTPS. Requests are received by both types of load balancers and they are distributed to a particular server based on a configured algorithm. This infrastructure security will use standard algorithms is round robin. The system will use two network load balancer devices diagram as bellow:

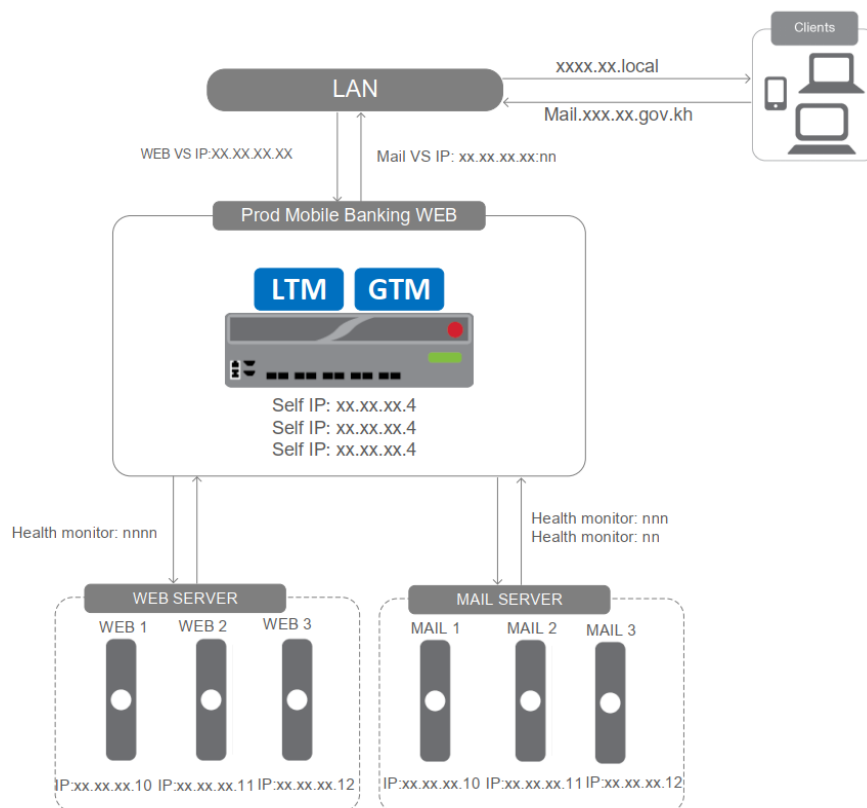


Figure 18: Load balancer topology

Load Balancer Key Specification

- Throughput: 20 Gbps L4/L7
- Processor: One 4-Core Intel Xeon processor

- Memory: 32 GB DDR4
- Gigabit Ethernet CU Ports: Optional SFP
- Gigabit Fiber Ports (SFP): 8 SX or LX (sold separately)
- Intelligent Traffic Processing

CHAPTER 4

RESULTS AND EVALUATION

After the pilot project of the new proposed IT Infrastructure security for system had been deployed, we keep to monitor and support. We noticed that the new Infrastructure has improved as well as satisfying from the users, network operation center and all so support for the following points as bellow:

4.1 Security Enhancement

By using the proposed new system of SIEM (splunk), it will help to improve the security for IT Infrastructure security for some special cases practitioners detect, investigate and respond to internal and external attacks by simplifying threat management while minimizing risk to safeguard, security operation with faster response times, improve their security posture by getting end-to-end visibility across all machine data, investigate threats and incidents, provide optimized incident response, and conduct breach analysis, compliance, and reporting for organization.

4.1.1 Security Posture

Identify and investigate security incidents with a suite of dashboards and workflows. security uses correlation searches to identify notable events in your environment that represent security incidents. Security posture provides a high-level overview of the notable events environment over the last 24 hours. Identify the security domains with the most incidents, and the most recent activity. See Security Posture dashboard. Incident review shows the details of all notable events identified environment, triage, assign, and review the details of notable events from this dashboard see incident review. Investigations shows all investigations in environment. Open and work investigations to track your progress and activity while investigating multiple related security incidents.

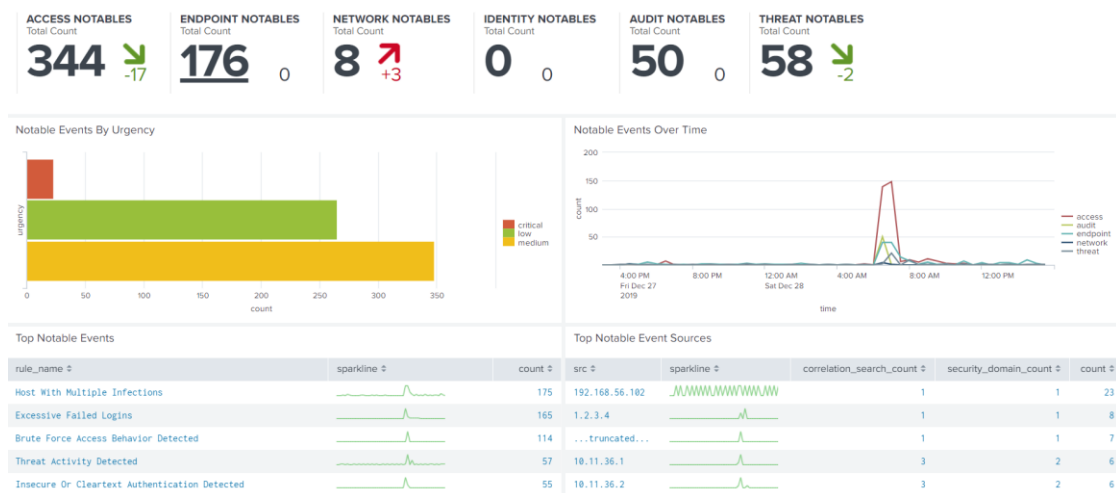


Figure 19: Security Posture

4.1.2 Security Incident review

Security incident review results in a list of practical actions that address each of the issues that allowed the threat actor to succeed. These actions should minimize the impact of an attack and teach the security team, the security tools, and the wider enterprise how to prevent, detect, and respond to a similar attack in the future.

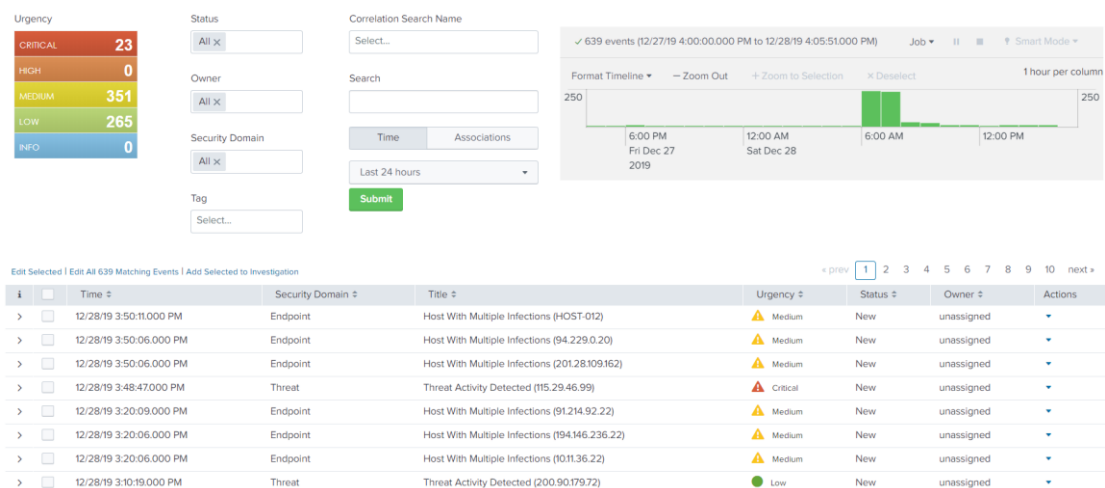


Figure 20: Security Incident review

Investigating a malware outbreak at organization, we can add hosts to the scope that we suspect are infected with malware without adding the associated events to the timeline and recording them as verifiably compromised. Add them to the scope first and review the relevant panels for additional context. If we discover that an artifact is part of the security incident we are investigating, we can add the event or detail that revealed that insight to the investigation to record that information for later.

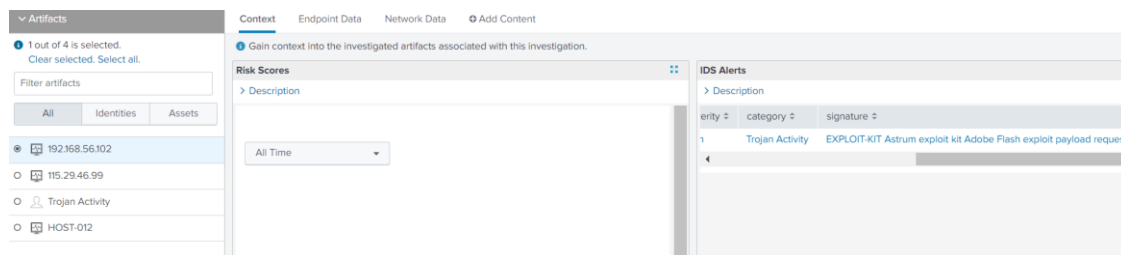


Figure 21: Security context

All so for threat activity detected we saw more event details show event ID, time and IP destination.

6:59 AM December 28, 2019

Notable Event: Threat Activity Detected (115.29.46.99) Action ▾

Overview
Details

Urgency critical

Status New

Owner unassigned

Description Threat activity (115.29.46.99) was discovered in the "dest" field based on threat intelligence available in the ip_intel collection

Event Details

event_id	7D54A62B-4CD6-4352-B115-DA9DD4084FD7@@@notable@@@a2623fe728550551fd968c49edc18403
event_hash	a2623fe728550551fd968c49edc18403
eventtype	notable, notable

Notable Event: Threat Activity Detected (115.29.46.99)

Figure 22: Security notable event

CHAPTER 5

CONCLUSION

5.1 Conclusion

In conclusion, Security based practices for an Organization IT Infrastructure have five layers as perimeter security, network security, endpoint security, OS/application security and data security. but for this not really enough because real situation we need to monitor and analysts with security log as SIEM solutions. It strong to analysts detect threats but, if not secured properly, can introduce vulnerabilities. An attacker's work is made more difficult if an organization properly secures its SIEM solution. Security concerns can be sorted by risk factor providing immediate action to reduce the attack surface and provide IT Infrastructure health. Splunk is armed with features and capabilities to combat suspicious network activity while generating report logs to adhere to industry policies and procedures. The key is to start with a central record of user and system activity and build an open architecture that lets different business users access the information to solve different business problems. So, there is no doubt in SIEM solutions helping the intrusion detection and response to improve to detect, prevent, protect, report on, and cyber security incidents. These incidents need to be managed and analyzed to better protect in the future as well. It protects both the hardware and software aspect as all company needs. This security-based practices will also work with industry and government regulations and standards.

5.2 Future Work

Another way to look at the future work section, is security cyber threat intelligence solutions (CTI) with Digital technologies lie at the heart of nearly every industry today. The automation and greater connectedness they afford have revolutionized the world's economic and cultural institutions but they've also brought risk in the form of cyberattacks. Threat intelligence is knowledge that allows you to prevent or mitigate those attacks. Rooted in data, threat intelligence provides context like who is attacking you, what their motivation and capabilities are, and what indicators of compromise in your systems to look for that helps you make informed decisions about your security.

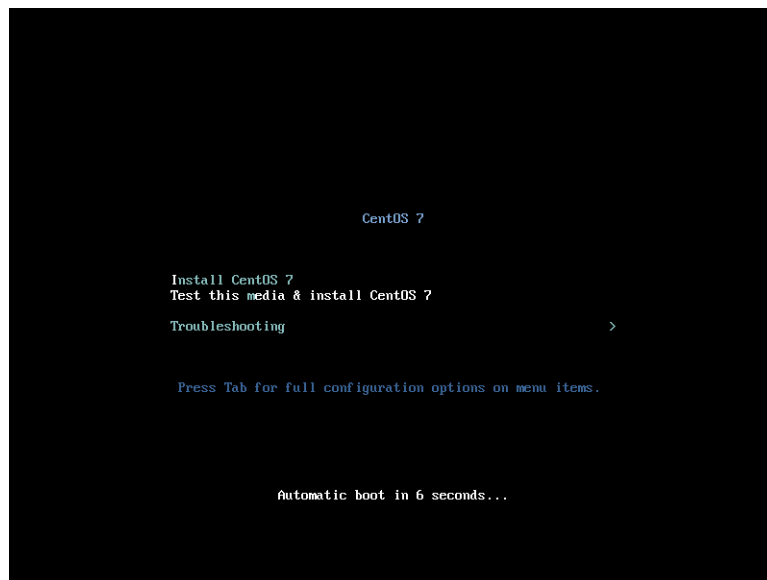
REFERENCES

- [1] J. Sokolowski, C. Turnitsa, and S. Diallo, “A conceptual modeling method for critical infrastructure modeling,” in Simulation Symposium, 2008. ANSS 2008. 41st Annual, April 2008, pp. 203 –211.
- [2] Gartner, Inc. “Security Information and Event Management”. Available: [Accessed: November 26, 2018]
- [3] M. Rouse. “security information and event management (SIEM)” . Available: - SIEM[Accessed: November 26, 2018]
- [4] Jennifer Jabbusch ,”IDS vs. IPS: How to know when you need the technology”, 22 November 2010
- [5] M. Pratt. “What is SIEM software? How it works and how to choose the right tool” Available: -how-it-works-and-how-to-choose-the-right-tool.html [Accessed: November 27, 2018]
- [6] Splunk “About Splunk” . Available: [Accessed: November 27, 2018]
- [7] “About Splunk App for PCI Compliance” . Available: [Accessed: November 27, 2018]
- [8] D. Cure. “May 2018 Product Reviews: SIEM and UTM-NGFW” . Available: [Accessed: November 28, 2018]

APPENDIXES

Appendix A: Installation and Configuration Centos7

Insert CentOS install disk and start the Computer. Then, following screen is displayed, Push Enter key to proceed.



Start Centos 7 with user root and password



Appendix B: Installation and Configuration SPLUNK (SIEM)

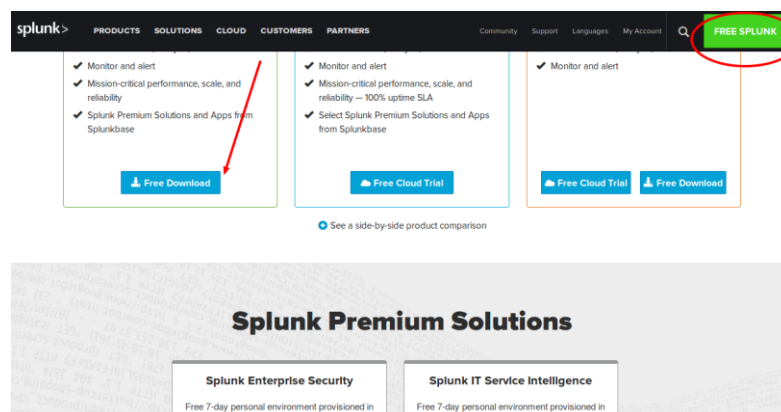
1. Create a Splunk User

It is always recommended to run this application as its dedicated user rather than as root. I created a user to run this application and created an application folder for the installation.

```
[root@RUPP tmp]# groupadd splunk
[root@RUPP tmp]# useradd -d /opt/splunk -m -g splunk splunk
[root@RUPP tmp]# su - splunk
[splunk@RUPP ~]$ id
uid=1001(splunk) gid=1001(splunk) groups=1001(splunk)
Confirm the server architecture
[splunk@RUPP ~]$ getconf LONG_BIT
```

2. Download and extract the Splunk Enterprise version

Create a Splunk account and download the Splunk software from their official website here.



Now extract the tar file and copy the files to the Splunk application folder namely /opt/splunk created.

```
[root@RUPP tmp]# tar -xvf splunk-6.4.0-f2c836328108-Linux-x86_64.tgz
[root@RUPP tmp]# cp -rp splunk/* /opt/splunk/
[root@RUPP tmp]# chown -R splunk: /opt/splunk/
```

3. Splunk Installation

Once the Splunk software is downloaded, you can login to your Splunk user and run the installation script. I choose the trial license, so it will take it by default.

```
root@RUPP tmp]# su - splunk
```

```
Last login: Sun Dec 01 08:14:12 UTC 2019 on pts/0
```

```
[splunk@RUPP ~]$ cd bin/
```

```
[splunk@RUPP bin]$ ./splunk start --accept-license
```

This appears to be your first time running this version of Splunk.

Copying'

```
/opt/splunk/etc/openldap/ldap.conf.default'to '/opt/splunk/etc/openldap/ldap.conf'.
```

Moving

```
'/opt/splunk/share/splunk/search_mrsparkle/modules.new'to
```

```
'/opt/splunk/share/splunk/search_mrsparkle/modules'.
```

```
Splunk> Australian for grep.
```

Checking prerequisites...

Checking http port [8000]: open

Checking mgmt port [8089]: open

Checking appserver port [127.0.0.1:8065]: open

Checking kvstore port [8191]: open

Checking configuration... Done.

Creating: /opt/splunk/var/lib/splunk

Creating: /opt/splunk/var/run/splunk

Creating: /opt/splunk/var/run/splunk/appserver/i18n

Creating: /opt/splunk/var/run/splunk/appserver/modules/static/css

Creating: /opt/splunk/var/run/splunk/upload

Creating: /opt/splunk/var/spool/splunk

Creating: /opt/splunk/var/spool/dirmoncache

Creating: /opt/splunk/var/lib/splunk/authDb

Creating: /opt/splunk/var/lib/splunk/hashDb

Checking critical directories... Done

Checking indexes...

Validated: _audit _internal _introspection _thefishbucket history main summary

Done

New certs have been generated in '/opt/splunk/etc/auth'.

Checking filesystem compatibility... Done

Checking conf files for problems...

Done

Checking default conf files for edits...

Validating installed files against hashes from '/opt/splunk/splunk-8.1

All installed files intact.

Done [OK]

Waiting for web server at http://127.0.0.1:8000 to be available.... Done

If you get stuck, we're here to help.

Look for answers here: <http://docs.splunk.com>

The Splunk web interface is at <http://RUPP.centos7-test.com:8000>